Creazione di una regola firewall per bloccare l'accesso alla DVWA da Kali Linux

1. Obiettivo

L'esercizio richiede di creare una regola firewall su pfSense che blocchi l'accesso alla DVWA (Damn Vulnerable Web Application), ospitata su Metasploitable, dalla macchina Kali Linux. Un requisito fondamentale è che le due macchine si trovino su reti diverse, con pfSense a fare da intermediario tra le due.

2. Configurazione dell'ambiente

Le macchine virtuali sono state configurate su UTM con la seguente topologia di rete:

- **Kali Linux** — IP: 192.168.50.100 | Rete: Condivisa (LAN di pfSense)
- **pfSense LAN** — IP: 192.168.50.254 | Interfaccia: em0
- **pfSense OPT1** — IP: 192.168.60.1 | Interfaccia: em1
- **Metasploitable** — IP: 192.168.60.101 | Rete: Solo Host (OPT1 di pfSense)

pfSense funge da router/firewall tra le due reti, con tre interfacce: WAN (verso internet), LAN (rete di Kali) e OPT1 (rete di Metasploitable).

3. Passi eseguiti

1. Aggiunta interfaccia OPT1 a pfSense in UTM — Aggiunta la terza scheda di rete (em1) tramite UTM e assegnata all'interfaccia OPT1 dalla Web GUI di pfSense (Interfaces → Assignments).
2. Configurazione OPT1 — Abilitata l'interfaccia OPT1 e assegnato IP statico 192.168.60.1/24 dalla Web GUI (Interfaces → OPT1).
3. Configurazione IP Metasploitable — Assegnato IP statico alla macchina Metasploitable con il comando:
   sudo ifconfig eth0 192.168.60.101 netmask 255.255.255.0
4. Configurazione gateway su Metasploitable — Aggiunto il default gateway per consentire la comunicazione con Kali attraverso pfSense:
   sudo route add default gw 192.168.60.1

5. Verifica connettività — Verificato che Kali riesca a pingare Metasploitable e ad accedere alla DVWA prima di applicare il blocco.

6. Individuazione porta DVWA con Nmap — Eseguita una scansione Nmap da Kali per identificare la porta su cui è in ascolto DVWA:
   nmap 192.168.60.101
   La scansione ha confermato che DVWA è raggiungibile sulla porta **80 (HTTP)**.

7. Creazione regola firewall di blocco — Creata la regola su pfSense (Firewall → Rules → LAN) con i seguenti parametri:
   - **Action:** Block
   - **Interface:** LAN
   - **Protocol:** TCP
   - **Source:** 192.168.50.100 (Kali Linux)
   - **Destination:** 192.168.60.101 (Metasploitable)
   - **Destination Port:** 80 (HTTP)

4. Verifica del risultato

Dopo l'applicazione della regola, sono stati eseguiti i seguenti test da Kali Linux:

- Ping verso Metasploitable: funzionante — le due macchine comunicano correttamente.
- Accesso HTTP alla DVWA (porta 80): bloccato — il firewall impedisce correttamente l'accesso.
- Nmap sulla porta 80: la porta risulta "filtered", confermando il blocco da parte di pfSense.

5. Conclusioni

L'esercizio ha dimostrato come pfSense permetta di creare regole firewall granulari, capaci di bloccare selettivamente il traffico verso una specifica porta di destinazione, mantenendo attiva la comunicazione generale tra le macchine. Questo approccio riflette un caso d'uso reale in ambito aziendale, dove si vuole limitare l'accesso a servizi specifici senza interrompere completamente la connettività tra segmenti di rete diversi.

```
┌──(kali㉿kali)-[~]
└─$ nmap 192.168.60.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-20 16:56 +0100
Nmap scan report for 192.168.60.101
Host is up (0.0025s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE    SERVICE
21/tcp   open     ftp
22/tcp   open     ssh
23/tcp   open     telnet
25/tcp   open     smtp
53/tcp   open     domain
80/tcp   filtered http
111/tcp  open     rpcbind
139/tcp  open     netbios-ssn
445/tcp  open     microsoft-ds
512/tcp  open     exec
513/tcp  open     login
514/tcp  open     shell
1099/tcp open     rmiregistry
1524/tcp open     ingreslock
2049/tcp open     nfs
2121/tcp open     ccproxy-ftp
3306/tcp open     mysql
5432/tcp open     postgresql
5900/tcp open     vnc
6000/tcp open     X11
6667/tcp open     irc
8009/tcp open     ajp13
8180/tcp open     unknown

Nmap done: 1 IP address (1 host up) scanned in 1.84 seconds

┌──(kali㉿kali)-[~]
└─$
```

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.60.101
PING 192.168.60.101 (192.168.60.101) 56(84) bytes of data.
64 bytes from 192.168.60.101: icmp_seq=1 ttl=63 time=1.04 ms
64 bytes from 192.168.60.101: icmp_seq=2 ttl=63 time=0.607 ms
64 bytes from 192.168.60.101: icmp_seq=3 ttl=63 time=0.675 ms
^C
--- 192.168.60.101 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2032ms
rtt min/avg/max/mdev = 0.607/0.772/1.035/0.187 ms

┌──(kali㉿kali)-[~]
└─$ curl https://192.168.60.101/dvwa
curl: (7) Failed to connect to 192.168.60.101 port 443 after 2 ms: Could not connect to server

┌──(kali㉿kali)-[~]
└─$
```